Capstone Report

Matt Guzman Fernandez

IS 4533-002

Professor Ervin

A client from HEB reached out to me mentioning that one Benjamin R. Brown, the primary suspect, hacked into the HEB servers and threatened to release the data of 1 million customers. It is a logic bomb, as the release of the data is timed to a certain point whether Brown is captured or not. My mission was to "defuse the bomb", so to speak, to prevent the data from being exposed. My client sent me four .zip files worth of evidence; one was from Brown's computer and the other three were from the three HEB servers that he allegedly hacked. Once I downloaded these files, I booted up my VM and got to work.

My first task was to head into SERVER-2's log files and find the log where the SQL injection took place (1). That log was "access_log_20250404.txt", indicating that Brown's SQL injection attack did indeed occur when he said it did, April 4, or early April. I discovered this information by using the yara rule "yara64.exe find_sql_injection.yar -r Logs". This uses the "find_sql_injection.yar" rule to search for "%201=@@version—" recursively (-r flag) in the log files located in the "Logs" folder.

1.

```
C:\Users\admin\Desktop\Capstone\SERVER-2>yara64.exe find_sql_injection.yar -r Logs
SQL_Injection_Found Logs\access_log_20250404.txt
```

I then entered this log file to find the IP address and the attack itself and was able to find evidence of both. The IP address used in the attack was "68.191.149.136", which is the address where the SQL injection attack indicator "%201=@@version—" originated from (2).

2.

```
14.116.156.77 - - [04/Apr/2025:08:36:48 -0400] "GET /index.html HTTP/1.1" 200 21576 "http://www.HEB.com" "Mozilla/5.0 (iPhone; CPU iPhone OS 13_2_3 li
68.191.149.136 - - [04/Apr/2025:08:39:50 -0400] "GET /search.asp?home=177&id=1%27%20or%201=0@version-- HTTP/1.1" 200 770 "-" "Mozilla/5.0 (Windows NT
```

Now that I had an IP address to work with, I went to search for mentions of “68.191.149.136” in SERVER-1’s files. I used a yara rule “find_brown_ip.yar” which just searches for the IP address I found in files and directories. The full command I used was to find the IP was “yara64.exe find_brown_ip.yar -r Files“. I found evidence of it in “winmedia.exe” at “Files\system32\Boot\en-US\winmedia.exe” (3) (4). This is the malware file Brown was referring to in his interrogation.

3.

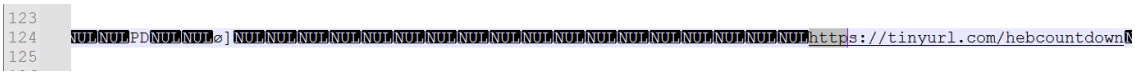
```
C:\Users\admin\Desktop\Capstone\SERVER-1>yara64.exe find_brown_ip.yar -r Files
Suspicious_IP_Found Files\system32\Boot\en-US\winmedia.exe
```

4.

```
winmedia.exe
t (c) Microsoft Corporation -->
```

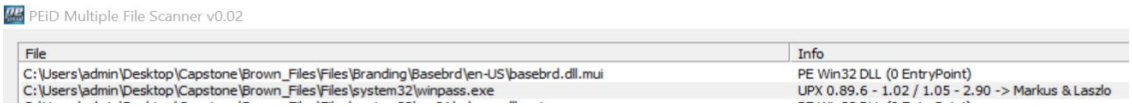
He also mentioned the website URL would be in this malware, so I searched further in this file and found it. The website URL is “https(:)//tinyurl(.)com/hebcountdown”, which I found by just hitting Ctrl + F and searching for “http” in the file (5). From here. I pivoted to finding the actual packed executable on the servers to begin the process of removing the malware entirely.

5.



To do this, I used PEID to search for any packed files on Brown’s computer itself. I used PEiD to look inside “Files” which is where all his files were stored, and I found that the file “winpass.exe” was packed. The file path was “Brown_Files\Files\system32\winpass.exe” (6).

6.



After finding the packed file, I wanted to confirm that this was indeed the suspicious file. I used the following command: “upx -t C:\Users\admin\Desktop\Capstone\Brown_Files\Files\system32\winpass.exe ”. Sure enough, this was confirmed to be the packed file (7).

7.

```
C:\Users\admin\Desktop>upx -t C:\Users\admin\Desktop\Capstone\Brown_Files\Files\system32\winpass.exe
                       Ultimate Packer for eXecutables
                          Copyright (C) 1996 - 2022
UPX 4.0.1       Markus Oberhumer, Laszlo Molnar & John Reiser   Nov 16th 2022

testing C:\Users\admin\Desktop\Capstone\Brown_Files\Files\system32\winpass.exe [OK]

Tested 1 file.
```

After confirming this was the right file, I went to unpack it. Before doing that though, I created a copy of the file with the name “winpass_unpacked.exe” to not tamper with the original file. I used the command “rename winpass.exe winpass_unpacked.exe ” to do so (8). I then used the command “upx -d winpass_unpacked.exe” to unpack the copy for analysis (9).

8.

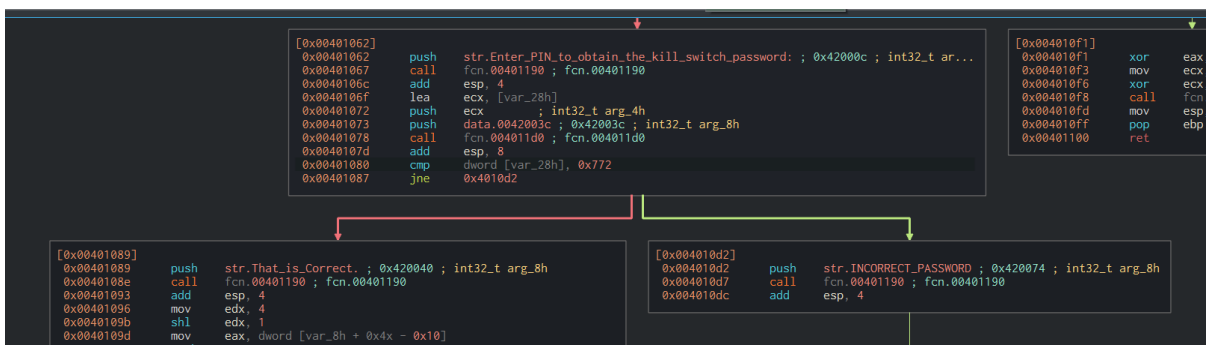
```
C:\Users\admin\Desktop\Capstone>rename winpass.exe winpass_unpacked.exe

C:\Users\admin\Desktop\Capstone>upx -d winpass_unpacked.exe
                       Ultimate Packer for eXecutables
                          Copyright (C) 1996 - 2022
UPX 4.0.1       Markus Oberhumer, Laszlo Molnar & John Reiser   Nov 16th 2022

        File size         Ratio      Format      Name
   --------------------   ------   -----------   -----------
    134656 <-     70144   52.09%    win32/pe     winpass_unpacked.exe

Unpacked 1 file.
```

9.

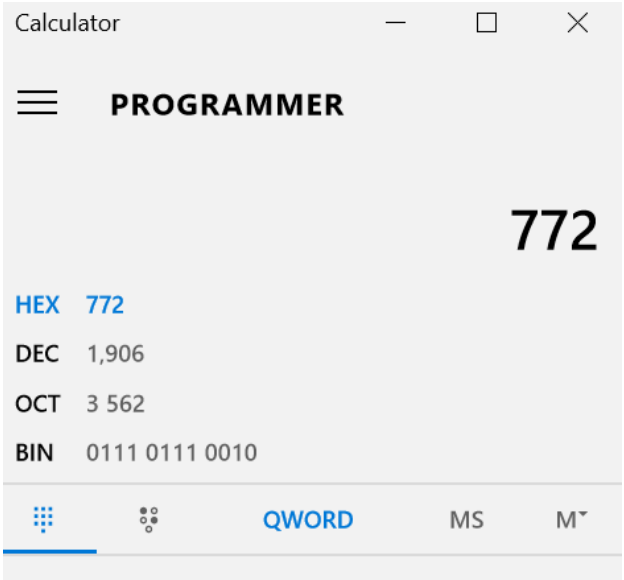

```
C:\Users\admin\Desktop\Capstone>rename winpass.exe winpass_unpacked.exe

C:\Users\admin\Desktop\Capstone>upx -d winpass_unpacked.exe
                       Ultimate Packer for eXecutables
                          Copyright (C) 1996 - 2022
UPX 4.0.1       Markus Oberhumer, Laszlo Molnar & John Reiser   Nov 16th 2022

        File size         Ratio      Format      Name
   --------------------   ------   -----------   -----------
    134656 <-     70144   52.09%    win32/pe     winpass_unpacked.exe

Unpacked 1 file.
```

Once I unpacked the copy, I opened the file in Cutter and determined that the password for the website was 1906. I checked the graph for the main function and saw that there was the function “cmp dword [var_28h], 0x772” inside (10). This is comparing whether the password is equal to the decimal equivalent of the hex value “772”, which is “1906” (11). If it is, it branches into the right section, the correct section. After this, we can find out what the kill switch is.

10.



11.



After discovering the PIN, I opened the file in x32dbg and filtered it by strings first to find where the password functions and calls were located. Like in Cutter, I noticed the “cmp 772” function here again and knew that it’d be the key to finding the kill switch (12). I created breakpoints to be able to manipulate the malware’s responses to give me the switch and inputted the password “1906” when I stepped into the malware and was prompted for it, and sure enough, it worked and gave me the kill switch: “unlock” (13) (14).

12.

```
002A1080    817D DC 72070000    cmp dword ptr ss:[ebp-24],772
```

13.

```
002A107D    83C4 08             add esp,8
002A1080    817D DC 72070000    cmp dword ptr ss:[ebp-24],772
002A1087    75 49               jne winpass_unpacked.2A10D2
002A1089    68 40002C00         push winpass_unpacked.2C0040        2C0040:"\n\nThat is Correct.\n"
002A108E    E8 FD000000         call winpass_unpacked.2A1190
002A1093    83C4 04             add esp,4
002A1096    BA 04000000         mov edx,4
002A109B    D1E2                shl edx,1
002A109D    8B4415 F0           mov eax,dword ptr ss:[ebp+edx-10]   [ebp+edx*1-10]:"Tú‰"
002A10A1    50                  push eax
002A10A2    B9 04000000         mov ecx,4
002A10A7    C1E1 00             shl ecx,0
002A10AA    8B540D F0           mov edx,dword ptr ss:[ebp+ecx-10]
002A10AE    52                  push edx
002A10AF    B8 04000000         mov eax,4
002A10B4    6BC8 00             imul ecx,eax,0
002A10B7    8B540D F0           mov edx,dword ptr ss:[ebp+ecx-10]
002A10BB    52                  push edx
002A10BC    68 54002C00         push winpass_unpacked.2C0054        2C0054:"The Kill-Switch is: %s%s%s\n\
002A10C1    E8 CA000000         call winpass_unpacked.2A1190
002A10C6    83C4 10             add esp,10
002A10C9    C745 EC 00000000    mov dword ptr ss:[ebp-14],0
002A10D0    EB 0D               jmp winpass_unpacked.2A10DF
002A10D2    68 74002C00         push winpass_unpacked.2C0074        2C0074:"INCORRECT PASSWORD!"
```

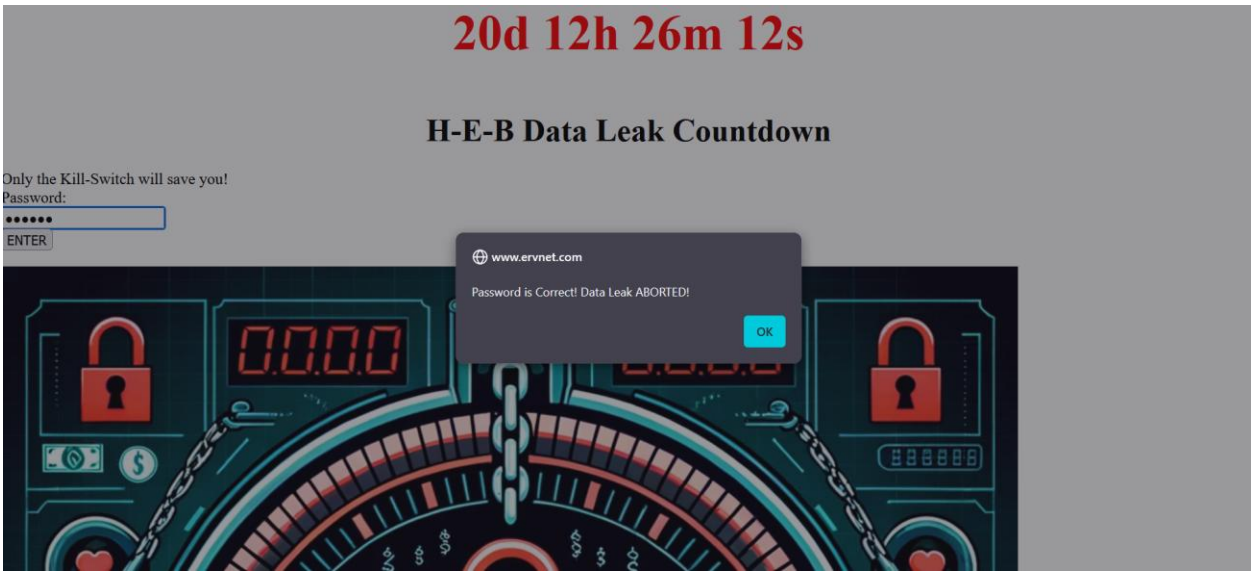
14.

C:\Users\admin\Desktop\Capstone\winpass_unpacked.exe

```
Enter PIN to obtain the kill-switch password: 1906


That is Correct.
The Kill-Switch is: unlock
```

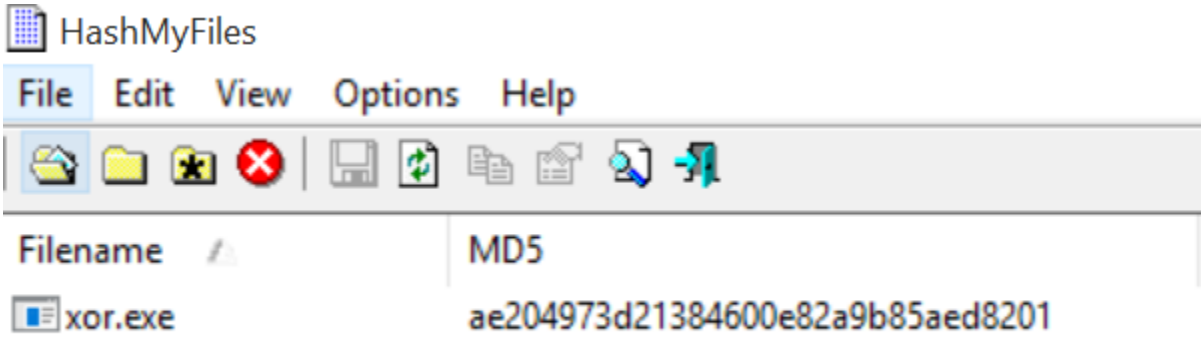
Immediately after discovering the kill switch, I went to the website I found earlier, “https(:)//tinyurl(.)com/hebcountdown” and inputted “unlock” as the password, and the “bomb” was defused (15).

15.



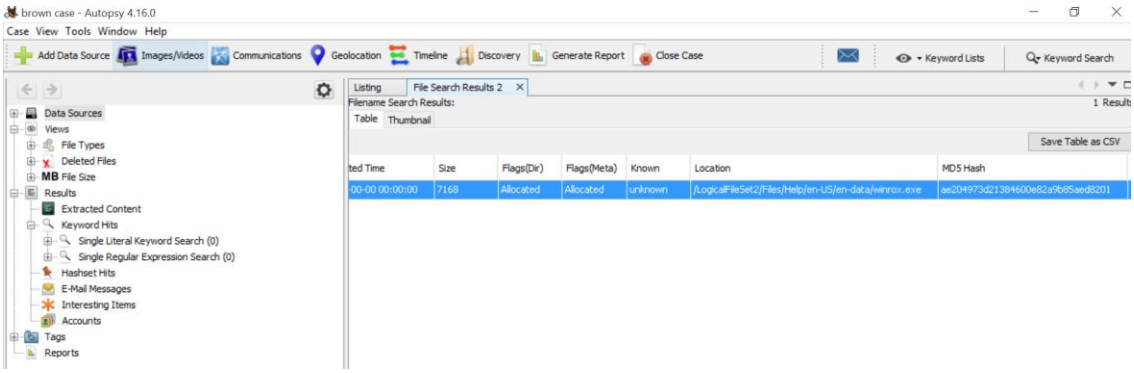
For the last portion of this case, I went to recover the evidence of the customers' data from SERVER-3. From the interrogation, we know that the XOR file in the server has the same hash as the one found in Brown's "tools" folder, so I went to hashmyfiles and found the MD5 has for his "xor.exe" file (16).

16.

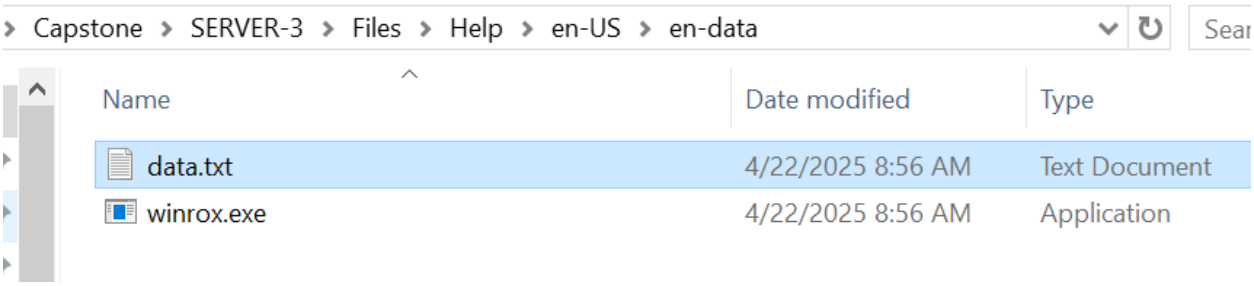


After this, I created a new case in Autopsy to check for this MD5 hash in the SERVER-3 files, and I searched by the MD5 in “File Search by Attributes”. I found that “winrox.exe” had the same hash as the “xor.exe” file in Brown’s computer (17). The file is located at “\Files\Help\en-US\en-data\winrox.exe” and so is the encrypted XOR data (18).

17.



18.



For the last steps, I just renamed the file to “xor.exe”, navigated to the directory in the command prompt, and used the command “xor.exe data.txt data_output.txt 2023” to decrypt the data into a readable format (19). “2023” was the key Brown gave us during the interrogation. The data was recovered, and the unencrypted file is shown here: (20).

19.

```
C:\Users\admin\Desktop\Capstone\SERVER-3\Files\Help\en-US\en-data>xor.exe data.txt data_output.txt 2023

Xor 0.2
by Luigi Auriemma
e-mail: aluigi@autistici.org
web:    aluigi.org

- input file: data.txt
- output file: data_output.txt
- text string key (hex dump follows):
32 30 32 33                                         2023
- read and xor file
- finished
```

20.

data_output.txt - Notepad

File Edit Format View Help

```
David,V,Moore,656-05-2708,803-804-2520,MasterCard,5115979163844711,033,12/2008
Michael,R,Hooper,213-42-1919,443-778-3523,Visa,4532742802517884,301,10/2008
Mirian,K,Smith,461-09-5022,936-895-4779,MasterCard,5599995079895519,570,6/2012
Wilmer,R,Richardson,326-34-4171,217-646-5440,Visa,4556261386372526,449,10/2012
Rafael,C,Taylor,232-88-5956,304-886-0948,Visa,4556230807111243,828,5/2008
Elaine,B,Glenn,296-30-8078,513-931-6747,Visa,4929884039352825,777,12/2010
Millard,K,Brown,340-56-2795,847-242-1932,Visa,4539183126761192,652,11/2009
Elizabeth,G,Ragland,659-10-8608,225-270-6857,Visa,4532629367275273,816,12/2011
Iva,R,Ball,453-07-0184,806-517-9121,MasterCard,5558763598809364,872,8/2012
Nicholas,T,Smith,553-89-4024,213-412-1040,Visa,4716329090918798,226,3/2008
Lisa,N,Marks,007-96-6061,207-777-6439,MasterCard,5203717634508827,790,6/2012
Linda,J,Homan,031-66-0686,617-586-9006,MasterCard,5557217172450815,089,10/2009
Alice,J,Jones,526-67-8230,520-557-1041,MasterCard,5125687710001697,127,10/2009
Sandra,K,Roberts,284-86-9602,216-621-0567,MasterCard,5599139458592609,368,12/2010
Stella,J,Amey,213-09-5079,301-855-1090,Visa,4716333191905704,629,7/2011
Nick,D,Roberts,244-99-9615,910-209-9632,Visa,4929555878584716,969,11/2010
Robert,R,Mcknight,040-42-5085,203-695-6367,Visa,4485180336076175,549,11/2008
Marilyn,D,Coffman,049-18-2652,203-347-9685,Visa,4485140309485712,842,10/2008
Stephen,M,Parker,460-17-5293,512-707-8963,MasterCard,5149939217893692,155,9/2010
Justin,L,York,414-17-0327,731-772-1560,MasterCard,5312750925897284,425,8/2008
Erin,L,Dickey,536-30-4518,509-581-9490,Visa,4539364185514744,805,6/2011
Kathleen,W,Carpenter,557-01-8922,949-742-7684,MasterCard,5287947933656428,831,11/2011
Vera,T,Gray,593-25-9842,352-282-6307,Visa,4485517374451747,943,11/2010
Anita,D,Fitzsimmons,533-23-4910,253-458-6499,Visa,4532629133133806,131,3/2008
Daniel,D,Haldeman,021-50-8793,413-248-3772,MasterCard,5433990114736828,470,6/2010
Sherry,E,Fierro,494-11-4182,660-214-9271,Visa,4716899002780114,552,1/2008
Lin,A,Corona,544-32-4267,541-995-9660,MasterCard,5513535720672306,048,6/2011
Ricky,M,Hamilton,299-36-4422,419-292-5945,MasterCard,5141132052163045,303,12/2008
Kenneth,E,Hebert,498-74-2511,417-796-7000,MasterCard,5186633241141905,403,6/2010
Jack,J,Hard,552-76-0617,650-231-8151,MasterCard,5282196565630807,532,4/2011
Annette,J,Harder,625-55-6653,323-775-9685,MasterCard,5252553774748216,477,2/2008
Evelyn,G,Larrabee,453-76-9580,979-820-4023,Visa,4485914102533088,902,11/2008
Ursula,M,English,554-53-2004,510-927-9477,Visa,4556373077041391,479,9/2008
Anthony,T,Hirsch,392-48-5455,920-929-6285,MasterCard,5470990358115527,425,9/2012
Ronald,A,Ross,541-65-4835,541-277-3508,MasterCard,5250717459574344,250,8/2010
```